

Internal Security Audit & Risk Assessment

Botium Toys — Controls and Compliance Checklist

Prepared by: Isaac Ekaniyere

Framework referenced: NIST Cybersecurity Framework (CSF) Identify function

Scope: Entire security program at Botium Toys all assets, alongside internal processes and procedures related to controls and compliance implementation

Context: Completed as part of the Google Cybersecurity Professional Certificate. Botium Toys is a fictional small U.S. toy retailer used as a training scenario; this is not a live client engagement.

Scope & Goals

The scope covers the entire security program at Botium Toys: all assets currently managed by the IT department, alongside the internal processes and procedures related to implementing controls and compliance best practices.

The goal of the audit is to assess existing assets and complete a controls and compliance checklist to determine which controls and compliance best practices need to be implemented to improve Botium Toys' security posture.

Background

Botium Toys is a small U.S. business that develops and sells toys, operating from a single physical location that serves as its main office, storefront, and warehouse. Its growing online presence — including sales to customers in the U.S. and abroad, and to customers in the European Union — has increased pressure on the IT department to support global operations, maintain compliance, and secure critical assets as the company scales.

Assets in Scope

- On-premises equipment for in-office business needs
- Employee equipment: end-user devices, remote workstations, headsets, peripherals, surveillance cameras
- Storefront products, held in the adjoining warehouse
- Managed systems and services: accounting, telecommunications, database, security, ecommerce, and inventory management
- Internet access and internal network
- Data retention and storage
- Legacy system maintenance (end-of-life systems requiring manual monitoring)

Risk Summary

Risk score: 8 / 10

The risk score is high due to a lack of implemented controls and inconsistent adherence to compliance best practices. The potential impact of asset loss is rated medium, since the IT department does not currently have full visibility into which assets are most at risk. The risk of fines from governing bodies is rated high, driven primarily by gaps in cardholder data protection and access control.

Controls Checklist

Each control below is assessed against evidence in the risk assessment report and mapped to the relevant control category (Administrative/Managerial, Technical, or Physical/Operational).

Control / Compliance Area	Status	Rationale
Least privilege	No	All employees currently have access to internally stored data, including cardholder data and customers' PII/SPII.
Disaster recovery plan	No	No disaster recovery plans currently exist, and there are no backups of critical data.
Password policy	No	A policy exists but requirements are nominal and do not meet minimum complexity standards (8+ characters, mixed case, numbers, special characters).
Account management policy (centralized password management)	No	No centralized system enforces password requirements; resets rely on manual IT tickets.
Separation of duties	No	Not implemented, alongside least privilege.
Firewall	Yes	A firewall is in place, configured with a defined set of security rules to block unwanted/malicious traffic.
IDS/IPS	No	The IT department has not installed an intrusion detection system.
Encryption	No	Credit card data is accepted, processed, transmitted, and stored locally without encryption.
Backups	No	No backups of critical data exist, consistent with the lack of a disaster recovery plan.
Antivirus (AV) software	Yes	Installed and monitored regularly by the IT department.
Physical controls (locks, CCTV, fire detection)	Yes	The physical premises have sufficient locks, up-to-date CCTV surveillance, and functioning fire detection/prevention systems.

Compliance Checklist

Compliance posture assessed against the regulatory frameworks relevant to Botium Toys' operations: payment card processing (PCI DSS) and sales to EU customers (GDPR), alongside general data integrity/availability controls (SOC).

Control / Compliance Area	Status	Rationale
PCI DSS (payment card data)	No	Cardholder data is not encrypted and is not restricted by least privilege or separation of duties — both required under PCI DSS.
SOC (data integrity & availability)	Yes	IT has ensured availability and has integrated controls to support data integrity.

Control / Compliance Area	Status	Rationale
GDPR (EU customers)	Yes	A 72-hour breach notification process for EU customers is in place, and privacy policies/procedures are documented and enforced.

Recommendations

- Implement encryption (at rest and in transit) for cardholder data the highest-priority gap given Botium Toys processes online payments.
- Adopt least privilege and separation of duties so access to PII/SPII and cardholder data is restricted by role rather than open to all employees.
- Deploy a centralized password management system enforcing complexity requirements aligned with current best practice.
- Build and test a disaster recovery plan, supported by regular backups of critical data.
- Deploy an IDS/IPS to complement the existing firewall, adding detection alongside prevention.
- Formalize a maintenance schedule for legacy systems rather than relying on ad hoc monitoring.

Note on this Document

This audit was completed as a hands on training exercise within the Google Cybersecurity Professional Certificate, using a fictional company scenario provided by the course. It is shared to demonstrate applied understanding of the NIST CSF, control categories, and compliance frameworks (PCI DSS, GDPR) not as evidence of a professional audit engagement.